ZCAS UNIVERSITY

MASTER OF SCIENCE IN CYBER SECURITY

CIT 5621

SYSTEMS AND INFORMATION SECURITY

FINAL EXAMINATION

FRIDAY 30th MAY 2025

TIME: 14.00 – 17.00 HOURS

TIME ALLOWED: THREE HOURS (plus 5 minutes to read through the paper)

INSTRUCTIONS

1. Section A: Question One in Section A is **compulsory**.
2. Sections B: Answer Two (2) questions from this section.
3. This examination paper carries a total of **100 marks**.
4. Candidates must **not turn this page** until the invigilator tells them to do so.
5. Your answers should reflect the Masters Degree level

PAGE INTENTIONALLY

LEFT BLANK

SECTION A: QUESTION 1 IS COMPULSORY AND MUST BE ATTEMPTED

Question 1:

Scenario: Read the scenario in Appendix A (also sent to you earlier), and then answer the questions below:

a) Explain the importance of implementing multi-factor authentication (MFA) in financial institutions like SecuBank. How does MFA address risks highlighted in the case study? (10 Marks)

b) Discuss the role of Role-Based Access Control (RBAC) in supporting the principle of least privilege. How does RBAC improve operational security at SecuBank? (10 Marks)

c) Design an access control matrix for SecuBank's investment division, including roles such as Analyst, Manager, and Auditor. Use R/W and – for Read, Write and No Access. (10 marks)

d) Evaluate how well-defined policies and procedures contribute to a secure organizational environment. Provide examples from the case. (10 Marks)

e) Explain the PDCA model in ISO 27001, and indicate how it supports continuous improvement in SecuBank's ISMS? (10 Marks)

[TOTAL: 50 MARKS]

SECTION B: ATTEMPT ONLY TWO QUESTIONS FROM THIS SECTION

Question 2:

Case Study: Cryptographic Security in FinSecure Ltd.

Page 1: Organizational Context

Background:

FinSecure Ltd. is a medium-sized financial technology (fintech) company headquartered in Toronto, Canada. It provides online micro-lending services to users across North America and stores sensitive personal and financial data on its cloud-based systems. With the increase in data breaches across the industry, FinSecure's management has mandated the integration of stronger cryptographic measures to protect user information and ensure secure communications.

Current Setup:

The company employs symmetric encryption (AES-256) to secure customer financial data at rest and uses TLS 1.3 for communications. Passwords are stored using SHA-256 with added salt. However, a recent security audit has revealed several weaknesses:

- Developers occasionally use hardcoded symmetric keys in mobile app code.
- Internal messaging still uses outdated Caesar-style obfuscation for debugging purposes.
- Public-key infrastructure (PKI) is not implemented for internal communications or code signing.
- No secure key exchange mechanism is in place for some mobile APIs.
- The company has never reviewed their transposition cipher use for internal testing.

Page 2: Recent Incident

Incident Report:

A security researcher discovered that FinSecure's Android app contained an exposed hardcoded symmetric key used for encrypting customer communications. An attacker could reverse-engineer the app and decrypt sensitive messages, putting customer data at risk. Additionally, the app's internal logs revealed messages encoded using a Caesar cipher for "security by obscurity," giving the attacker insight into internal operations.

Emergency Response Measures:

1. The security team immediately removed the hardcoded key from the app.
2. A patch was issued, replacing the key with a randomly generated one derived during a secure session.
3. The Caesar cipher debugging tool was removed.
4. Plans are being developed to implement RSA-based asymmetric encryption for mobile communication and Diffie-Hellman for secure session key generation.

Page 3: Strategic Implementation

Planned Cryptographic Enhancements:

1. **Symmetric Encryption (AES)** will be retained for data at rest.
2. **Asymmetric Encryption (RSA-2048)** will be implemented for user authentication and digital signatures.
3. **Hybrid Cryptosystem** combining RSA for key exchange and AES for session encryption in mobile and web apps.
4. **Public Key Infrastructure (PKI)** will be established to handle certificate issuance and verification.
5. **One-Time Pads and Vigenère Ciphers** will be explored in training to improve developer understanding, not for production.
6. **Hash Functions**: Passwords will now be hashed using bcrypt or Argon2 to mitigate brute-force attacks.
7. **Cryptographic Policies**: All developers will be required to follow updated cryptographic standards and avoid ad hoc implementations.

8. **Security Education**: Developers and DevOps staff will receive training on cryptographic best practices and secure key management.

Questions:

a) Explain the difference between symmetric and asymmetric encryption. Provide examples of each. (5 Marks)

b) Given the ciphertext "KHOOR ZRUOG" encrypted using the Caesar cipher, decrypt it, (assuming a shift of 3 in the alphabet) (5 Marks)

c) Encrypt the plaintext "ATTACKATDAWN" using the Vigenère cipher with the keyword "LEMON". (5 Marks)

d) Explain a cryptographic hash function, and what its primary properties are? (5 Marks)

e) Discuss the role of key exchange protocols in cryptography. (5 Marks)

[TOTAL: 25 MARKS]

Question 3:

Case Study: Ethical Hacking Engagement at MedLock Health Systems

Background:

MedLock Health Systems is a private healthcare provider managing sensitive patient data through an integrated EHR (Electronic Health Record) system. After increasing ransomware attacks in the healthcare sector, MedLock's board authorized a red team/blue team exercise involving an **external ethical hacking consultancy**, RedCore Security, to assess vulnerabilities in their authentication mechanisms.

Scope of Engagement:

- External and internal penetration testing.
- Web application testing focused on the patient portal and admin dashboard.
- Password audit of 1,000 employee credentials using ethical password cracking techniques.
- Evaluation of policy compliance regarding password complexity and change frequency.

Findings:

1. **Password Reuse**: 35% of passwords cracked via **dictionary attacks** were reused across systems.
2. **Weak Passwords**: 22% of passwords were under 8 characters and lacked complexity.
3. **Hashing Issues**: Some user passwords were still stored using **unsalted SHA-1** hashes.
4. **Phishing Vulnerability**: 12 staff credentials were compromised through a **simulated phishing campaign**.
5. **Lack of MFA**: Administrative interfaces lacked multi-factor authentication (MFA).
6. **Toolset Used**: Tools included **John the Ripper**, **Hydra**, and **Hashcat** for cracking; **Metasploit** and **Burp Suite** for testing.
7. **Legal and Ethical Protocols**: All activities were authorized under a signed Rules of Engagement document.

Recommendations:

- Migrate to **bcrypt** or **Argon2** for password hashing.
- Enforce **MFA** on all sensitive access points.
- Apply **complex password policies** with enforced expiry.
- Conduct quarterly phishing simulations.
- Incorporate ethical hacking in internal risk management cycles.

Questions:

a) Discuss the five phases of ethical hacking, and explain how RedCore applied them in the case? (5 Marks)

b) Using a table, distinguish Vulnerability Scanning and Penetration testing? (5 Marks)

c) RedCore Security found that 22% of MedLock's 1,000 employee passwords were weak (less than 8 characters). Assuming an average attacker can brute-force 1 billion (10^9) password guesses per second, and the average weak password has a keyspace of 62^8 combinations (alphanumeric only), estimate the maximum time it would take to crack one weak password using brute-force. Is this an acceptable risk? (5 Marks)

d) If 35% of employee passwords are reused across systems and RedCore cracked 300 unique passwords, decide how many user accounts might be exposed if each reused password applies to 3 systems on average? (5 Marks)

e) During a phishing simulation, RedCore compromised 12 staff accounts. Assuming each staff member had access to files containing protected health information (PHI) and each file averaged 25 patient records, estimate the potential data breach size. What are the possible legal implications?)5 Marks)

[TOTAL: 25 MARKS]

Question 4:

Case Study: NetSure Ltd – A Targeted Network Security Breach

Background:

NetSure Ltd. is a medium-sized managed service provider (MSP) offering secure internet and cloud-based services to small businesses across Europe. Their network infrastructure includes:

- A central data center housing virtual machines (VMs)
- An enterprise firewall
- IDS/IPS systems
- VPN-based remote access
- Active Directory for access control
- Segregated VLANs for internal departments

In March 2025, NetSure experienced a **major network breach** involving:

- Unauthorized lateral movement across VLANs
- Data exfiltration via an encrypted tunnel
- Exploitation of a **zero-day vulnerability in a VPN appliance**
- Weak segmentation and **lack of micro-segmentation**
- Poor **patch management** practices
- Outdated cryptographic protocols (e.g., use of TLS 1.0)

The incident response revealed:

- The attacker gained **initial access via stolen VPN credentials**.
- Intrusion went undetected for weeks due to **improper IDS configuration**.
- Logs were being stored but not **correlated or monitored effectively**.
- Network devices had **default credentials** enabled.

NetSure launched a full forensic investigation and overhauled their network security strategy.

Questions:

a) Explain how zero-day vulnerabilities impact network security. How should organizations respond? (5 Marks)

b) Explain lateral movement in a cyber attack and how can it be prevented? (5 Marks)

c) You are hired to redesign NetSure's VLAN architecture. List three design principles for secure VLAN implementation. (3 Marks)

d) Discuss the principle of least privilege and explain how applying it would reduce the breach impact at NetSure? (7 Marks)

e) Design a network security checklist for preventing similar breaches at NetSure. Include at least 5 key items. (5 Marks)

APPENDIX A

Case Study: SecuBank's Information Security Transformation

Background

SecuBank is a mid-sized financial institution operating across five countries, providing retail and investment banking services to over 2 million customers. The bank has recently experienced increased regulatory scrutiny and several minor security incidents involving unauthorized access to internal systems. An internal audit revealed systemic weaknesses in identity management, inconsistent access controls across departments, lack of security awareness, and outdated policies and procedures.

In response, the Chief Information Security Officer (CISO) launched an initiative to transform SecuBank's security posture. The bank committed to aligning with **ISO/IEC 27001**, the international standard for Information Security Management Systems (ISMS). The transformation program was designed around five pillars: robust **authentication mechanisms**, improved **access control and protection**, updated **policies and procedures**, adherence to **ISO 27001 controls**, and implementation of a mature **ISMS** framework.

Authentication and Access Control

The audit revealed that 35% of staff accounts still used single-factor authentication, and privileged access was inconsistently granted. Multi-Factor Authentication (MFA) was mandated for all critical systems. Role-Based Access Control (RBAC) was introduced, with access defined based on the principle of least privilege. The bank implemented a centralized Identity and Access Management (IAM) system to automate provisioning and de-provisioning of user access.

Policies, Standards, and Procedures

SecuBank reviewed all security policies, including acceptable use, incident response, and access control. These were rewritten to align with ISO 27001's Annex A controls. The bank established a governance committee to periodically review and approve policies. A new "Policy Exception" procedure was created to address business-specific deviations while maintaining risk awareness.

ISO 27001 and ISMS Implementation

SecuBank conducted a comprehensive risk assessment to identify threats to information assets. It adopted ISO 27001:2022, establishing its ISMS under the "Plan-Do-Check-Act" (PDCA) model. The ISMS includes asset inventories, risk treatment plans, continuous monitoring, and internal audits. Key performance indicators (KPIs) were implemented to measure ISMS effectiveness. A gap analysis showed improvement areas such as internal audit cycles, control testing frequency, and documentation maturity.

Challenges and Forward Strategy

While significant progress was made, challenges remained. Legacy systems limited full automation of access controls. Cultural resistance to change slowed the adoption of new procedures. The CISO's team developed a roadmap to enhance user training, improve legacy system integration with the IAM, and increase automation of compliance reporting.

END